

OT-Sicherheit am Bahnhof

Herausforderungen des sicheren Betriebs verteilter Systeme

21.01.26
23:13:31

v3.4.6

Warm-up 1

Michael Stumpp

Wofür benötigt man *Embedded Systems* am Personenbahnhof?

Hinweis: Die Leit- und Sicherungstechnik (LST) ist auch im Bahnhof ein Teil des Fahrwegs und zählt daher hier nicht.



Warm-up 2

Michael Stumpp

Dafür benötigt man *Embedded Systems* am Personenbahnhof

- Aufzüge und Fahrtreppen
- Heizungssteuerung
- Steuerung der Lüftung (auch Klima)
- Videoüberwachung (in der Kamera)
- Steuerung der Beleuchtung
- Netzersatzanlagen-Steuerung
- Dynamische Werbetafeln
- Verbrauchszähler (Strom, Wärme, …)



- Anzeigetafeln
- Zugzielanzeiger
- Dynamische Schriftanzeiger
- Brandmeldeanlagen
- Einbruchsmeldeanlagen
- Aufzugsnotruf
- Frequenzzählung Fahrgäste
- Winterdienst-Überwachung

OT-Sicherheit am Bahnhof

Michael Stumpp

Agenda

Operationale Technologie bei der Eisenbahn
- Struktur der Eisenbahn / Operationale Technologie

Gebäudeautomation
- Teilbereich der Operationalen Technologie

OT-Sicherheit am Bahnhof
- Bedrohungen / Besonderheiten / Maßnahmen

Handlungsfelder der OT-Sicherheit
- Konvergenz / Betriebsführung / Security-Pragmatismus

Einordnung: Regulierung und Praxis
- ISO 27001 / IEC 62443 / IT-SIG / NIS 2 / CRA / TR-03183

Fazit

Dozent



Michael Stumpp
Diplominformatiker

Berufserfahrung
- 40 Jahre IT Branche
- 12 Jahre Deutsche Bahn AG
  - IT-Sicherheitsprojekte
  - IT-Betrieb am Bahnhof
  - IT-Sicherheit Gebäudeautomation

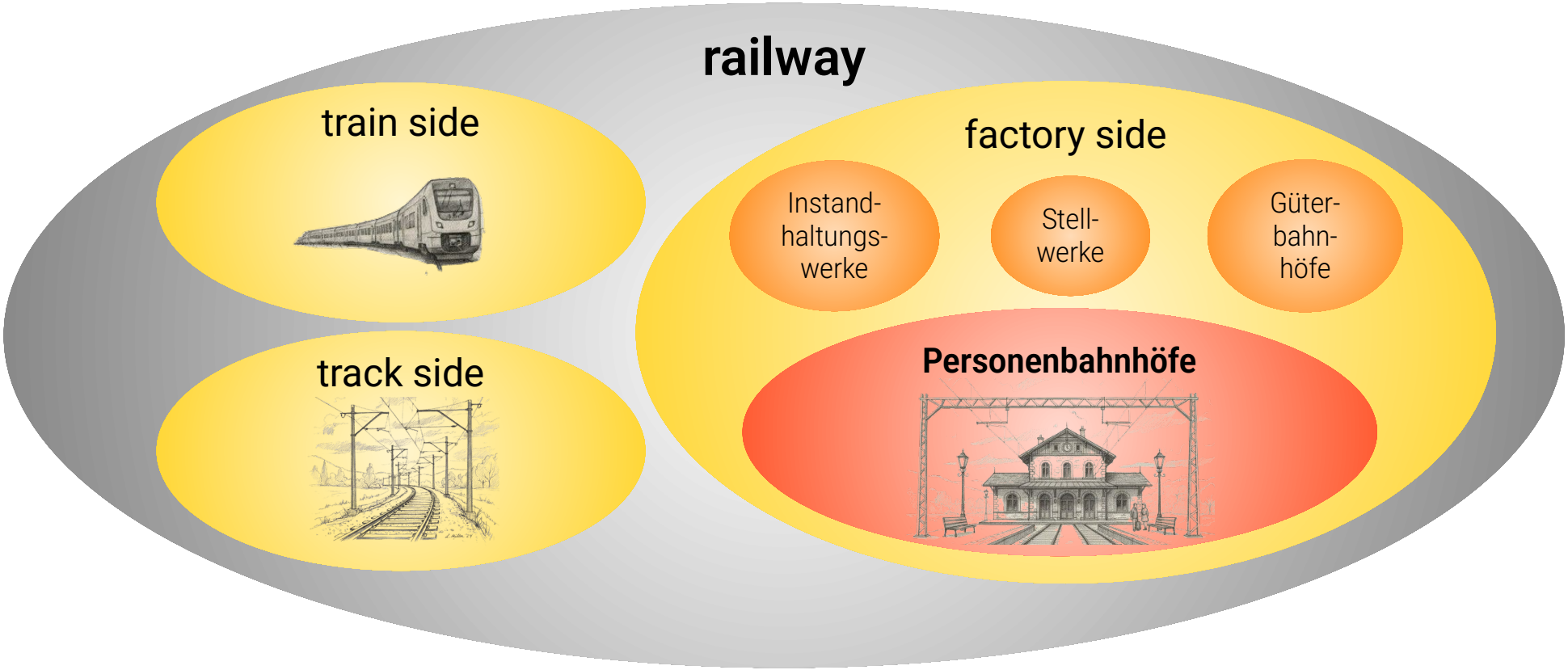
Schwerpunkte
- IT-Sicherheit Operationale Technik
- IT-Betrieb dezentraler Infrastruktur
- Awareness in der IT-Sicherheit

Kontakt

michael@stumpp.name
@m-e-st:tchncs.de
@M_E_ST@mastodon.social

Struktur der Eisenbahn

Michael Stumpp



Operationale Technologie im Personenbahnhof 1

Michael Stumpp

HKL-Steuerung
Heizung Kühlung Lüftung

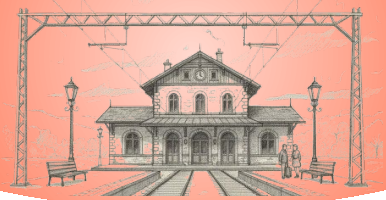
Bahnhofsleitstände
3-S-Zentralen Gebäudeleittechnik

Reisendeninformation
Beschallung Fahrgastinformation DSA

Höhenfördertechnik
Fahrtreppen & Aufzüge

Videoüberwachung
Kameras Videoserver Auswertung

Personenbahnhöfe



Zählertechnik
Strom Wasser Gas Wärme

Gefahrenmeldeanlagen
Brandmelder Einbruchsmelder Aufzugsnotruf

Beleuchtungssteuerung
Allgemein- und Sicherheitsbeleuchtung

Fahrscheinsysteme
Ticket-Automaten Fahrschein-Schalter

Energieersatzanlagen
Notstromgeneratoren USV-Systeme

Zutrittskontrolle
Zugangs- und Türsteuerung

Digital Signage
Digitale Werbeanzeiger

Operationale Technologie im Personenbahnhof 2

Michael Stumpp







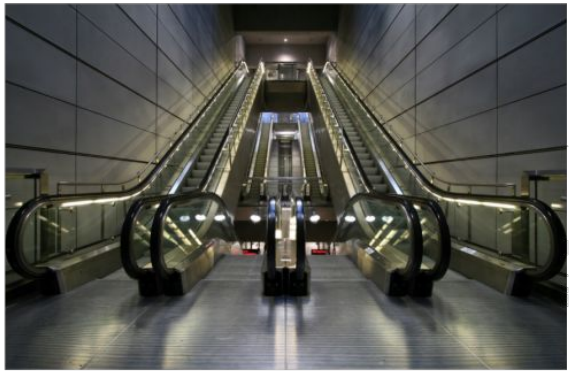






Operationale Technologie im Personenbahnhof 3

Michael Stumpp







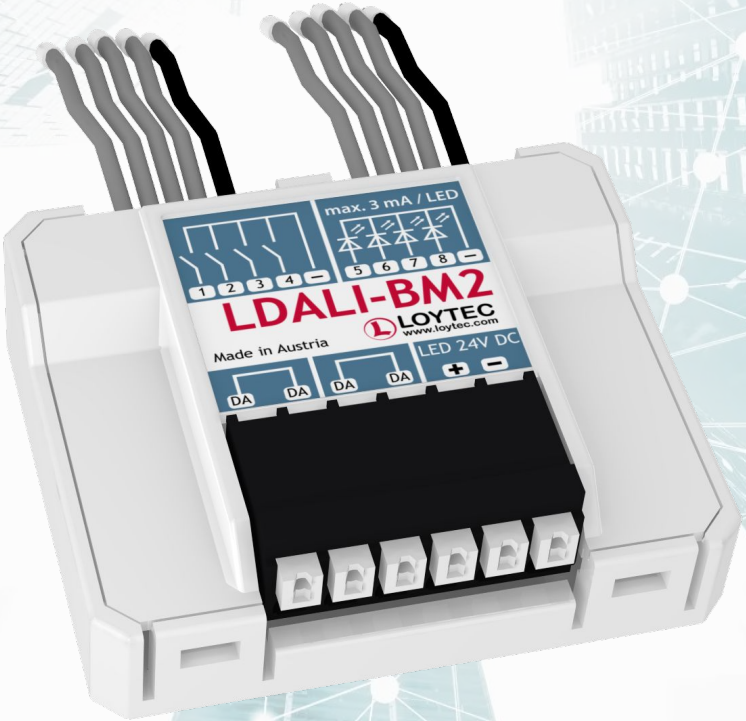






Gebäudeautomation als Teil der Operationalen Technologie

Michael Stumpp



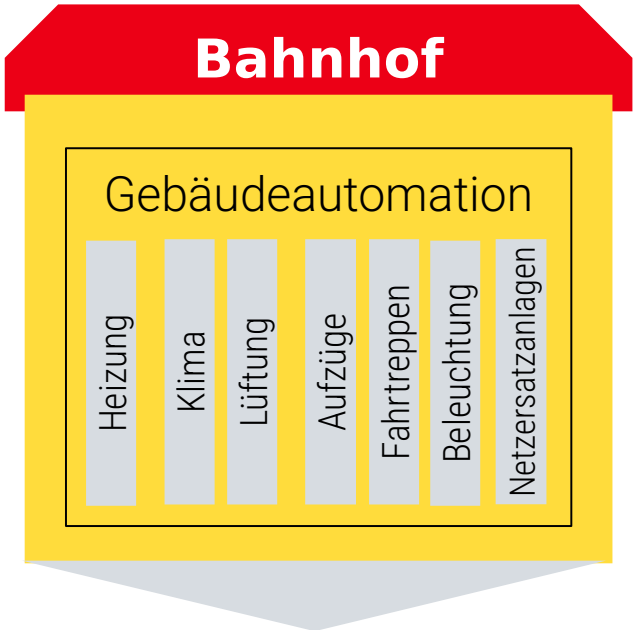
Anlagen der Technischen Gebäudeausrüstung

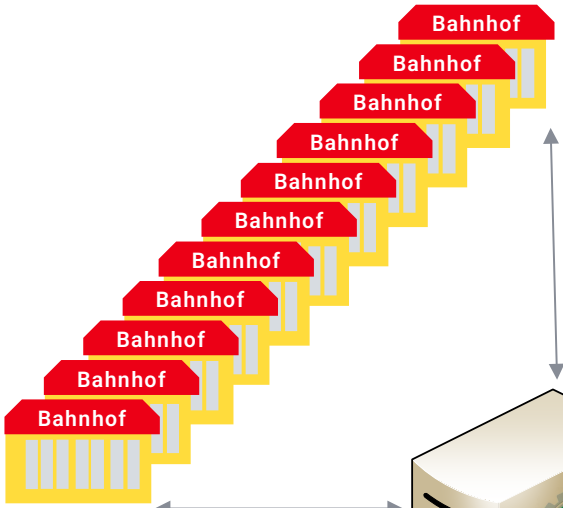
Michael Stumpp

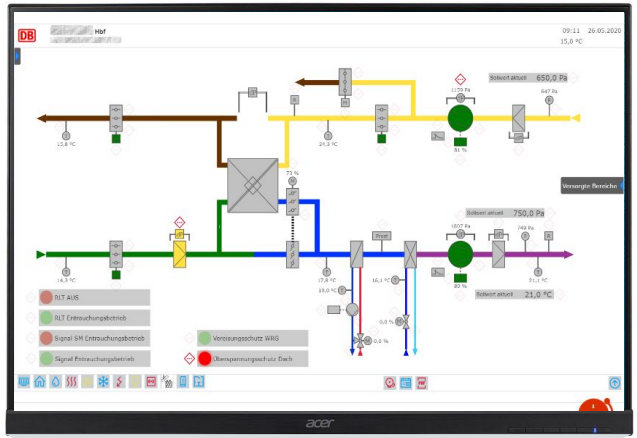
- **Anlagen der Versorgungstechnik**
  - **Heizung**
  - **Lüftung**
  - **Klima**
  - **Wasser**
  - **Zähler** (Strom, Gas, Wasser, …)
- **Sicherheitsanlagen**
  - Zutrittskontrolle
  - *Videoüberwachung*
  - Einbruchmeldeanlagen
  - Brandmeldeanlagen
  - Aufzugnotruf
- **Transportanlagen**
  - **Aufzüge**
  - **Fahrtreppen**
- **Elektrotechnische Anlagen**
  - **Allgemeinbeleuchtung**
  - **Sicherheitsbeleuchtung**
  - **Notstromaggregate (NEA)**
  - Unterbrechungsfreie Stromversorgung (USV)
- **Fahrgastinformation**
  - *Zugzielanzeiger*
  - *Dynamische Schriftanzeiger*
  - Bahnhofsuhren
- **Weitere Bahnhofs-Systeme**
  - Winterdienst
  - *Kunden-WLAN*
  - *Frequenzanalyse*

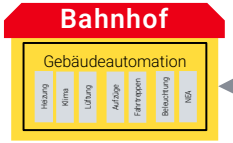
Aufbau der Gebäudeautomation

Michael Stumpp



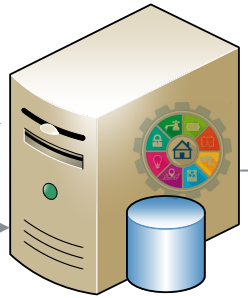


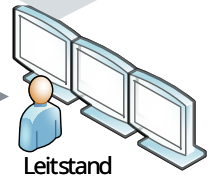




Fernüberwachung

- Anlagenzustände
- Betriebsparameter
- Störungen





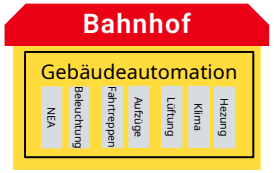
Struktur der Gebäudeautomation - SCADA

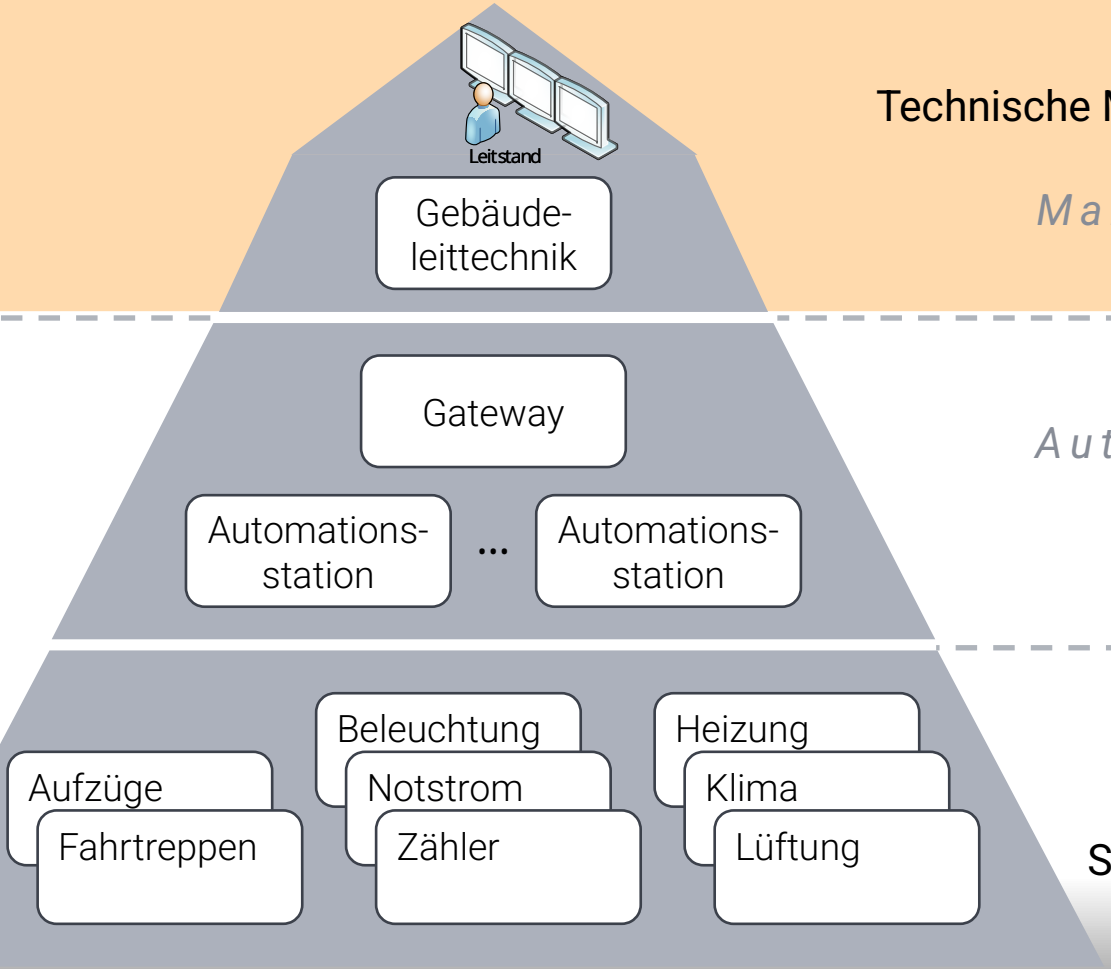
Michael Stumpp

Zentrale Technik

Gebäudeautomation am Bahnhof







Leitstand
Technische Managementzentrale

Managementebene
Gebäudeleittechnik

Automationsebene

Feldebene
Sensoren und Aktoren

Technischer Aufbau der Gebäudeautomation am Bahnhof

Michael Stumpp

Die Gebäudeautomation am Bahnhof ist hierarchisch und deterministisch aufgebaut. Sie folgt dem klassischen SCADA-Aufbau und unterscheidet sich grundlegend von einer IT-Architektur.

Feldebene	Automationsebene	Managementebene
Sensoren&Aktoren • Temperatur, CO2, Rauch • Klappen, Ventile, Belüftung • Beleuchtung	DDC-GA-Controller • technisch meist SPS oder Embedded Controller	GLT | BMS | SCADA Typisch: • Zentrale Leitwarte • Fernzugriff für Wartungsfirmen
Kommunikation: • 2-Draht-Busse • Typisch: BACnet MS/TP, Modbus RTU, M-Bus, LON	Kommunikation: • Feldbus zum Controller • IP-fähig, aber OT-Konzepte	Kommunikation: • BACnet/IP • UDP/IP (Broadcasts!) • nicht cloud-fähig
Eigenschaften: • Echtzeitnah • Robust • oft keine Authentifizierung • keine Verschlüsselung	Aufgaben: • Regelung (PID) • Logik (Wenn-Dann-Funktionen) • Lokaler Betrieb ohne Leitsystem	Funktionen: • Visualisierung • Zeitprogramme • Alarmierung • Historisierung

OT-Sicherheit am Bahnhof

Michael Stumpp



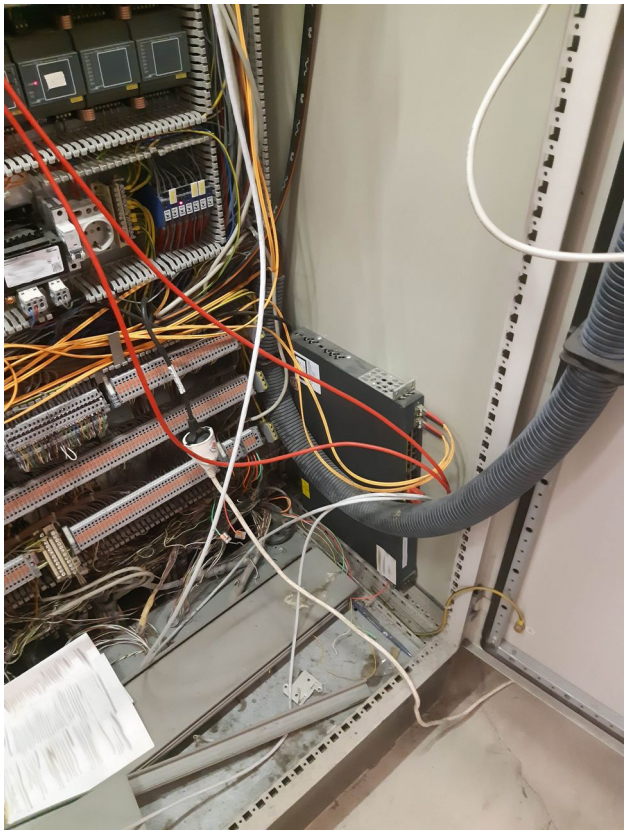
Sicherheitsvorfälle der Operationalen Technologie

Michael Stumpp

- Freitag, der 13te – Ransomware-Befall beim Wartungsdienstleister
  → Keine Rekonfiguration der Belüftungsanlage → drohende Bahnhofs-Evakuierung.
- die Passwort-Rücksetztaste – Designfehler eines LAN-Routers der GA
  → Drohende Offenlegung aller Netzwerk-Credentials und -Zertifikate auf Tastendruck.
- das Steuerpanel der Netzersatzanlage – Windows im Technikraum
  → Das Steuerpanel einer großen Anlage zeigt bei Fehlbedienung den Windows-7-Prompt.
- das WannaCry-Desaster 2017 – die Fiktion der isolierten Datennetze
  → Der WannaCry-Wurm erreicht öffentlichkeitswirksam das isolierte Bahnhofsdatennetz
- Sabotage eine Lieferanten-Technikers – glücklicherweise nur eine Übung
  → Ein versteckter RaspBerry sendet nach Karenzzeit unsinnige Statusmeldungen.
- Selbstabschaltung der Zugzielanzeiger – Versagen eines Lieferanten
  → Ein Fehler in der Qualitätssicherung legt ⅓ aller Zugzielanzeiger lahm.

Sabotage eine Lieferanten-Technikers

Michael Stumpp



- TableTop-Übungen erlauben es, die Lösung von fiktiven Sicherheitsvorfällen durchzuspielen.
- Die Annahme war, dass der Techniker eines Lieferanten einen RaspBerry-Pi-Rechner im Schaltschrank versteckt hat, der nach drei Monaten anfing, BACnet-Störmeldungen zu verbreiten.
- In Zusammenarbeit zwischen Gebäudeautomation und IT-Security konnte das Problem in vierzehn Spielzeit-Tagen (real ca. 90 Minuten) erkannt und gelöst werden.
- Solche Übungen helfen, das Zusammenspiel für Notfälle zu üben, sowie prozessuale Schwachpunkte zu finden und zu beheben.

Warum klassische IT-Security hier versagt …

Michael Stumpp

- IT-Security schützt **Daten**
- OT-Security schützt **physische Prozesse**
- IT denkt in Usern, Sessions und Logs
- OT denkt in Zyklen, Sollwerten und Regelkreisen
- UDP-basierte Protokolle (z. B. BACnet/IP)
  - → keine Sessions
  - → keine Authentisierung
- „Abschalten bei Angriff“ ist keine Option
- Safety & Verfügbarkeit haben Vorrang vor Vertraulichkeit

Was OT-Security stattdessen leisten muss …

Michael Stumpp

- Schutz von **Prozessen**, nicht primär von Daten
- Sicherstellung von **Determinismus und Echtzeitfähigkeit**
- Begrenzung von **Schreibzugriffen** auf Steuerfunktionen
- Trennung von **Lesen** (Monitoring) und **Schreiben** (Steuern)
- Erhalt des Betriebs auch **unter Angriff oder Fehlkonfiguration**
- Integration in **Safety- und Betriebsprozesse**
- Sicherheit über **den gesamten Lebenszyklus** (20–40 Jahre)

Was ein einzelnes BACnet-Write auslösen kann …

Michael Stumpp

Ein einzelnes gültiges BACnet-Telegramm kann folgende Aktion auslösen:

```
WriteProperty
Object: Analog Output 3
Property: Present_Value
Value: 0
```

- Lüftungsanlage stoppt
- Rauchabzug bleibt geschlossen
- Fahrtreppe schaltet ab
- Notbetrieb wird nicht ausgelöst
- Leitstand zeigt: „Befehl gültig“

Gebäudeautomation: **Kein technischer Exploit.**
Kein Malware-Code.
Nur ein fachlich korrekter Wert.

Die IT-Sicherheit nennt das hingegen einen "Unvalidated Input" auf der Prozessebene.

… wären da nicht übergeordnete Sicherheitsregeln.

Michael Stumpp

Einschränkungen

- Der Änderungsbefehl ist offen einsehbar – auch am Leitstand
- Am Leitstand erzeugt ein solcher `manual operator` einen Alarm.
- Konkret bleibt z.B. die Fahrtreppe zwar stehen; wird jedoch gemeldet.

SPS Applikationen sind gesichert

- Applikationen auf einer SPS (PLC) sind oft gegen Schreibbefehle gesichert.
- Besonders bei SAFETY-Anwendungen erfolgt die Einrichtung ohne BACnet.
- Darüberhinaus sind schreibbare Parameter oft über Wertebereiche gesichert.

Ursachen und Gegenmaßnahmen zum BACnet-Write Exploit

Michael Stumpp

Ursachen

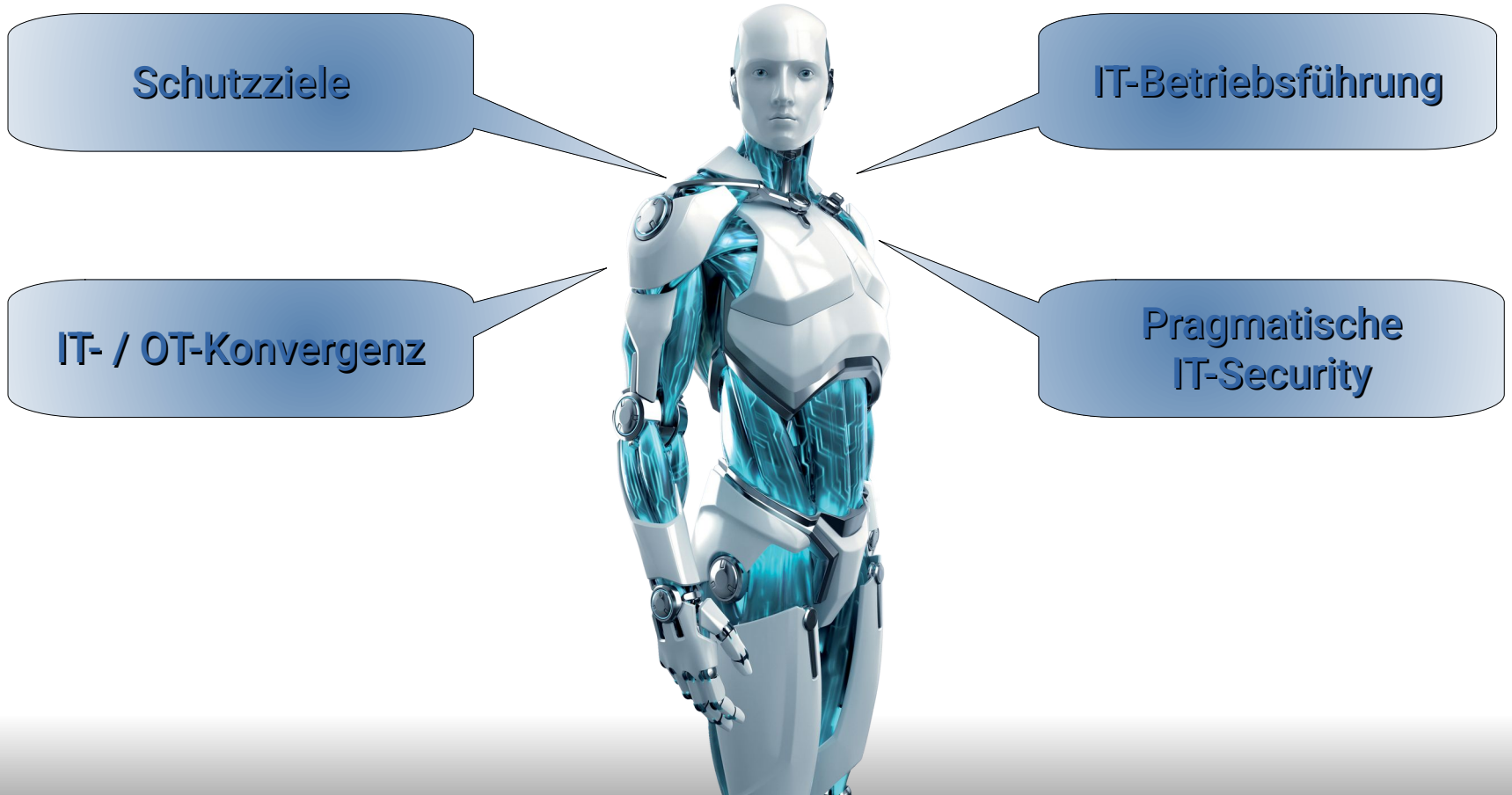
- Historisches Design – BACnet ist optimiert auf Interoperabilität
- Vertrauen auf Netzwerk – BACnet erwartet physikalisch isolierte Netze.
- Reale Implementierung – `WriteProperty` wird zur Inbetriebnahme benötigt.

Gegenmaßnahmen

- Netzwerksegmentierung ✅
- Gerätehärtung ⚠️
- Verschlüsselung – BACnet Clause 24 oder BACnet/SC ❌
- Validierung im Controller – Verriegelung kritischer Änderungen im DDC ✅
- Monitoring – Überwachung des BACnet-Verkehrs auf Anomalitäten ⚠️

Handlungsfelder der OT-Security

Michael Stumpp



IT vs OT - Klassische IT versus Operationale Technologie

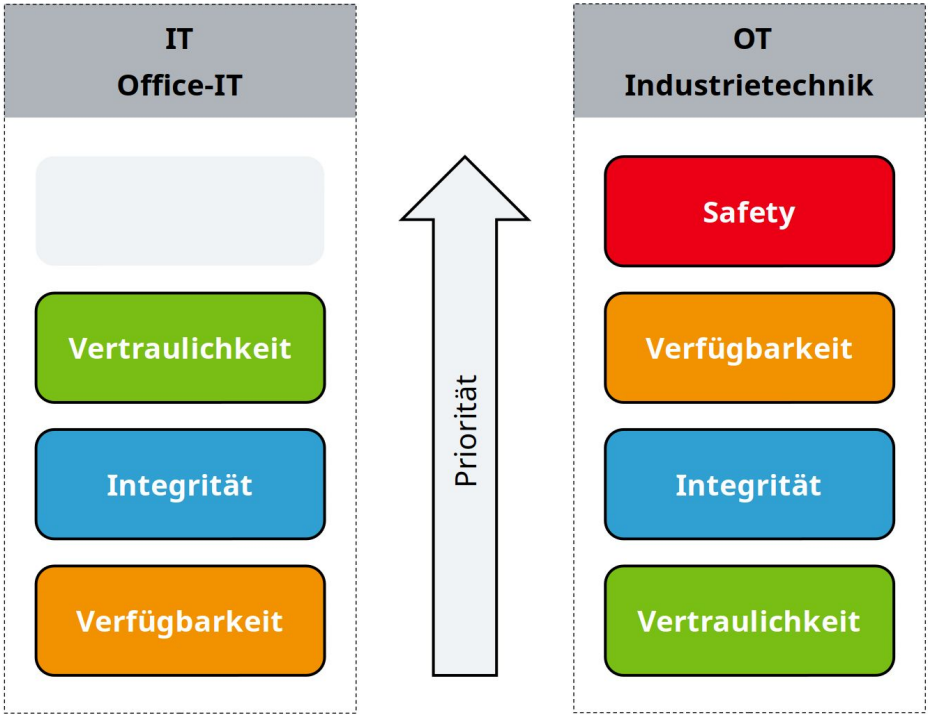
Michael Stumpp

	IT-Welt	OT inkl. GA
Lebenszyklen	3 – 5 Jahre	20 – 40 Jahre
Verfügbarkeit	Hoch, aber nicht kritisch	Safety-relevant
Updates (Patchen)	regelmäßig, automatisch normativ verpflichtend	oft nicht möglich teilweise unzulässig
Netzwerk	Standard TCP/IP-Netzwerke gesichert, verschlüsselt Strukturierte Netzverkabelung	Ethernet, UDP/IP (z.B. BACnet/IP) 2-Draht Feldbusse (z.B. Modbus) Indivuelle Netzarchitekturen
Sicherheitsziel	Vertraulichkeit > Verfügbarkeit	Verfügbarkeit > Vertraulichkeit

Unterschiedliche Schutzziele von IT und OT

Michael Stumpp

- Die klassische IT stellt immer die Vertraulichkeit über die Verfügbarkeit. Bevor ein System ungewollt Daten abgibt, wird es lieber abgeschaltet.
- Die OT der Industrietechnik stellt immer die Verfügbarkeit vor die Vertraulichkeit. Bevor ein System nicht mehr funktioniert, riskiert man lieber die Preisgabe von Daten.
- In der OT gibt es das zusätzliche und wichtigste Schutzziel **„Safety“** für das es kein Gegenstück in der klassischen Office-IT gibt.



IT- / OT-Konvergenz: Annäherung zweier Welten

Michael Stumpp

- IT und OT behalten **unterschiedliche Rollen und Ziele**
- Gemeinsames Verständnis für **Risiken und Abhängigkeiten**
- Keine vollständige Vereinheitlichung der Technologien
- Ziel: **Koordinierte Schnittstellen**, nicht Verschmelzung
- Klare Abgrenzung von IT-, OT- und Safety-Domänen
- Gemeinsames Risikoverständnis, keine Tool-Übertragung
- OT-Systeme bleiben betriebsautonom

Einführung einer geordneten IT-Betriebsführung

Michael Stumpp

- Zuständigkeiten & Verantwortlichkeiten klären
- Dokumentation statt „Anlagenwissen im Kopf“
- Kontrollierte Änderungen statt Ad-hoc-Eingriffe
- Nachvollziehbarkeit von Konfigurationen & Zugriffen
  - Wer? Wann? Was? Warum?
- Betrieb wird **reproduzierbar und prüfbar**

Dies erfordert einen Kulturwandel in der OT und der Gebäudeautomation.

IT-Security: Pragmatismus statt Dogma

Michael Stumpp

- Beherrschbarkeit statt Perfektion
- Pragmatische **teilweise Anwendung** in der IT bewährter Mechanismen
- Akzeptanz von **Legacy-Systemen**
- Sicherheit als **Management von Risiken**, nicht als Absolutziel
- Schutz durch Transparenz, Zonierung und Prozesse
- Ziel: **Stabiler Betrieb auch im Fehlerfall**

Dies erfordert einen Kulturwandel der IT und der IT-Sicherheit.

Einordnung: Regulierung und Praxis

Michael Stumpp



Gesetzliche Anforderungen an Personenbahnhöfe 1

Michael Stumpp

IT-Sicherheitsgesetz (IT-SiG) gilt seit 2015 für Betreiber kritischer Infrastrukturen im Verkehrssektor, einschließlich großer Bahnhöfe. Als Stand der Technik wurde die Umsetzung der ISO 27001-Anforderungen festgelegt.

NIS-2-Richtlinie gilt für die DB InfraGO AG als Betreiber wesentlicher Einrichtungen und erfasst damit das gesamte Bahnhofsnetz (ca. 6.000 Bahnhöfe).

Die Anforderungen von NIS-2 gehen deutlich über die bisherige ISO 27001-Umsetzung für das IT-SiG hinaus. Gefordert sind u.a.:

- Umfassendes IT-Risikomanagement
- Information Security Management System (ISMS, z.B. nach ISO/IEC 27001)
- Business Continuity Management System (BCMS)
- Lieferketten-Cybersicherheit
- Incident Response und Meldepflichten

Gesetzliche Anforderungen an Personenbahnhöfe 2

Michael Stumpp

OT-Sicherheit: NIS-2 gilt explizit auch für alle OT-Systeme (Operational Technology), einschließlich Gebäudeautomation, Zugsteuerungssysteme und Infrastruktur-komponenten.

Technische Umsetzungsstandards:

- IEC 62443 ist der etablierte internationale Standard für Industrial Security und wird als Best Practice für OT-Cybersicherheit empfohlen
- ISO/IEC 27001/27002 für ISMS-Anforderungen
- BSI TR-03183 (Cyber-Sicherheitsanforderungen für Netzwerke) kann als Orientierung für spezifische technische Umsetzungen herangezogen werden.

Cyber Resilience Act (CRA): Die EU-Verordnung verpflichtet Hersteller von Produkten mit digitalen Elementen zu Cybersicherheitsanforderungen über den gesamten Produkt-lebenszyklus. Dies betrifft Lieferanten von Bahnhofstechnik (z.B. Gebäudeautomation, Anzeigesysteme, Zugangskontrolle) und stärkt indirekt die Sicherheit der Betreiberinfra-struktur.

ISO 27000 versus IEC 62443

Michael Stumpp

	ISO 27000 Familie	IEC 62443 Reihe
Name	Information Security Management Systems (ISMS)	Industrial communications networks – Network and system security
Fokus	Informationssicherheit für Organisationen	Cybersicherheit für Industrie-, Automatisierungs- und Steuerungssysteme (IACS) / Operational Technology (OT)
Ziele	Aufbau, Implementierung, Aufrechterhaltung und kontinuierliche Verbesserung eines ISMS	Definition technischer, organisatorischer und prozessualer Anforderungen zum Schutz von Automatisierungs- und Steuerungssystemen über den gesamten Lebenszyklus
Bestandteile	ISO 27001 – Anforderungen ISMS ISO 27002 – Maßnahmenkatalog ISO 27005 – Risikomanagement	62443-2-1 – Sicherheitsrichtlinien und Verfahren 62443-3-3 – Systemanforderungen 62443-4-2 – Komponentenanforderungen
Prioritäten	Datenorientiert – Vertraulichkeit, Integrität, Verfügbarkeit	Betriebsorientiert – Verfügbarkeit und Integrität sind wichtiger als Vertraulichkeit

Problemfelder der Gebäudeautomation

1

Michael Stumpp

Vendor-Lockin

„isoliertes" Datennetz



Geräte-"Zoo"

Wartung & Service

Lange Einsatzdauer

Fehlendes IT-Knowhow

Problemfelder der Gebäudeautomation 2

Michael Stumpp

- das Vendor-Lockin-Problem
  → Jeder Hersteller produziert inkompatible Anlagen, um die Kundenbindung zu erhöhen.
- das Geräte-“Zoo“-Problem
  → Anlagen wurden zu unterschiedlichen Zeiten über verschiedene Ausschreibungen errichtet.
- die lange Einsatzdauer der Systeme
  → Eine Anlage der Technischen Gebäudeausrüstung hat eine Lebensdauer von 20 – 40 Jahren.
- die Annahme eines isolierten Datennetzes
  → Auch Netze ohne Internet-Anbindung sind angreifbar – besonders am Bahnhof.
- das Wartung- und Service-Problem
  → Wartung und Service wird von externem Personal mit deren Hard- und Software durchgeführt.
- das IT-Knowhow-Problem
  → IT-Probleme werden von Automatisierungs-Ingenieuren gelöst – auch beim Gerätehersteller.

IT-Betriebsführung nach ITIL – Best Practice

Michael Stumpp

Service Transition – Überführung in den Betrieb

- Change Management – Gesteuerte Durchführung von Änderungen
- Release & Deployment Management – Planung und Auslieferung neuer Releases
- Configuration Management – Verwaltung von Konfigurationsdaten (CMDB)
- Knowledge Management – Aufbau einer Wissensdatenbank
- Ziel: Risikominimierung bei Änderungen, kontrollierte Einführung

Service Operation – Täglicher IT-Betrieb

- Incident Management – Schnelle Wiederherstellung bei Störungen
- Problem Management – Analyse und Behebung von Ursachen
- Event Management – Überwachung und Reaktion auf Ereignisse
- Request Fulfillment – Bearbeitung von Service-Anfragen
- Access Management – Rechteverwaltung und Zugriffskontrolle
- Ziel: Stabiler, zuverlässiger Betrieb mit minimalen Ausfallzeiten



IT-Betriebsführung nach ITIL – Nutzen

Michael Stumpp

Nutzen für den IT-Betrieb:

- Klare Verantwortlichkeiten und Prozesse
- Schnellere Störungsbehebung
- Dokumentierte Änderungen und Konfigurationen
- Höhere Verfügbarkeit der IT-Services

Ergebnisse:

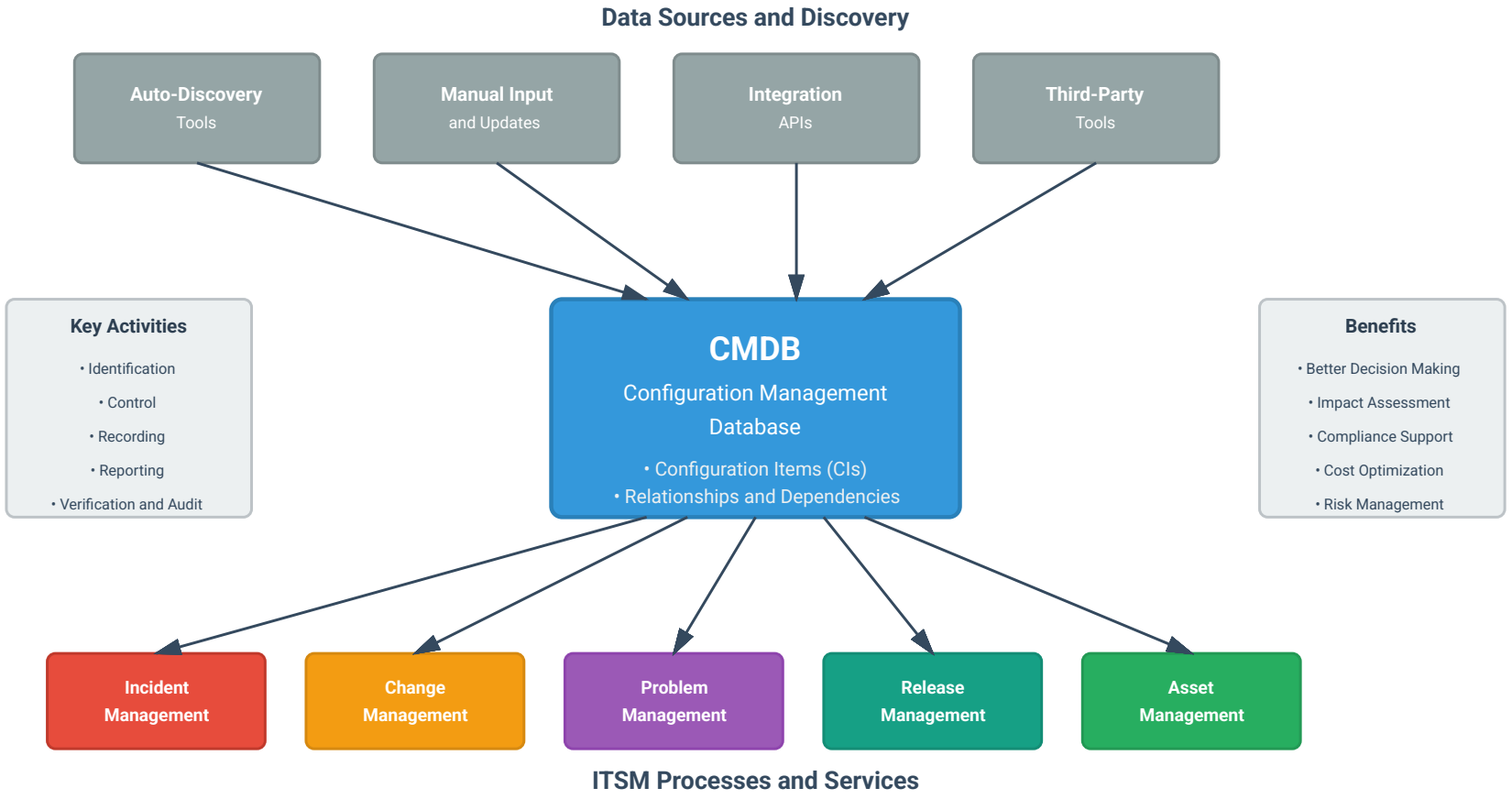
- Weg von implizitem Anlagenwissen
- hin zu Dokumentation & Zuständigkeiten
- Geplante Änderungen statt Ad-hoc-Eingriffe
- Nachvollziehbarkeit von Konfigurationen & Zugriffen
- Betrieb wird reproduzierbar und prüfbar



Dies erfordert einen Kulturwandel in der OT und der Gebäudeautomation.

ITIL Service Asset & Configuration Management (SACM)

Michael Stumpp



Single Source of Truth for IT Infrastructure and Services

Fazit



Erkenntnisse 1

Michael Stumpp

OT-Sicherheit am Bahnhof: Drei notwendige Kulturwandel

- **IT/OT-Konvergenz – Annäherung, nicht Verschmelzung**
  - Konvergenz bedeutet **Koordination**, nicht Gleichmacherei.
- **Geordnete IT-Betriebsführung –** *Kulturwandel der OT*
  - Ziel ist **Beherrschbarkeit**, nicht maximale Automatisierung.
- **Beherrschbarkeit statt Perfektion** – *Kulturwandel der IT-Security*
  - Sicherheit wird **operativ handhabbar**, nicht theoretisch perfekt.

Security ist kein reines Technikproblem.
Sie entsteht aus dem Zusammenspiel von Technik, Betrieb und Organisation.

Erkenntnisse 2

Michael Stumpp

Entscheidend für die OT-Sicherheit ist …

- Embedded Systeme sind **Teil sicherheitskritischer Prozesse**
- Fachlich korrekte Steuerbefehle können **gefährlich** sein
- Sicherheit beginnt **im Design**, nicht im Nachrüsten
- Betriebsfähigkeit ist ein **nicht-funktionales Requirement**
- Dokumentation und Nachvollziehbarkeit sind **Sicherheitsfunktionen**
- Autonomie vor Ort ist ein **Security-Feature**

**Wer Embedded Systems für Bahninfrastruktur baut,
baut Verantwortung für Jahrzehnte.**

Erkenntnisse 3

Michael Stumpp

Die OT-Security kann von der Erfahrung der IT-Security profitieren

- IT-Security-Vorgehensweisen sind über Jahrzehnte gereift.
- OT-Security war in der Vergangenheit kein großes Thema.
- Die IT-Security-Verfahren sind nicht 1:1 auf die OT und GA übertragbar.
- Pragmatisch angewandt, kann die OT-Security von der IT profitieren.
- Dies erfordert jedoch ein Umdenken auf beiden Seiten.

Die Basics der IT-Security sind ein Fortschritt für die OT-Security, wenn sie pragmatisch und mit Augenmaß angewandt werden.



Vielen Dank für Ihre Aufmerksamkeit